

Oscorp Cybersecurity Risk Analysis

R-01 — Cybersecurity Governance & Risk Management

Supporting Findings

The NIST CSF assessment identified several deficiencies affecting Oscorp's ability to consistently identify, prioritize, and manage cybersecurity risk:

- No formal cybersecurity risk management process.
- No defined cybersecurity risk appetite or tolerance.
- Cybersecurity roles and responsibilities are not fully formalized.
- No comprehensive information security policy.
- Cybersecurity threats and business impacts are not formally assessed and documented.
- Assets and systems are not consistently prioritized based on business criticality.

NIST CSF 2.0 Alignment

CSF 2.0 subcategory	Connection to Oscorp finding
GV.RM-02	Risk appetite and tolerance are not defined.
GV.RM-06	A standardized approach to recording and prioritizing cybersecurity risk is not established.
GV.RR-02	Cybersecurity responsibilities and authorities are not fully formalized.
GV.PO-01	An organization-wide cybersecurity policy is not established.
ID.AM-05	Assets are not consistently prioritized by business criticality.

The following selected CSF 2.0 outcomes are relevant to the scenario-based findings. These mappings are analyst interpretations, not independently verified compliance determinations.

Risk Scenario

Because Oscorp lacks a formal cybersecurity governance and risk management structure, significant cybersecurity risks may not be consistently identified, prioritized, assigned to responsible owners, or remediated within appropriate timeframes.

This could result in critical risks remaining untreated while resources are allocated to lower-priority issues.

Business Impact

- Compromise of critical systems or sensitive information.
- Operational disruption from preventable security incidents.
- Increased incident response and recovery costs.
- Inefficient allocation of cybersecurity resources.
- Delayed remediation due to unclear accountability.

Existing Controls

- Existing cybersecurity and IT personnel.
- Established business strategy and objectives.
- Documented network and cloud architecture.
- Existing business continuity and disaster recovery processes.
- Existing technical security controls.

Likelihood: 3/5

Rationale: They have some existing controls and personnel but if something was to come up, they wouldn't have a set plan or know how to handle it quickly and efficiently which can lead to risks not being mitigated correctly.

Impact: 3/5

Rationale: If a private customer database is exposed to the public, you can not only be responsible for fixing the situation but can also be financially responsible for the impact. The missing controls don't lead directly to a breach, but could have the possibility and if there is no POA in place, then this could lead to a major breach or operational issues.

Current Risk

Score: $3 \times 3 = 9/25$

Risk Treatment

Mitigate

Recommended Actions

1. Establish a formal cybersecurity risk management process and risk register.
2. Define cybersecurity roles, responsibilities, and risk ownership.
3. Establish risk appetite and tolerance criteria.
4. Develop and approve an information security policy.
5. Establish recurring cybersecurity risk assessments.
6. Classify systems and information based on business criticality.
7. Establish recurring management review of material cybersecurity risks.

Expected Risk Reduction

A formal governance program would improve Oscorp's ability to identify risks, assign accountability, prioritize remediation, and provide management visibility into cybersecurity exposure.

Roadmap Priority

P3

R-02 — Identity & Privileged Access Management

Supporting Findings

- Multi-factor authentication is not implemented.
- Shared privileged administrator credentials exist.
- Privileged Access Management (PAM) is not implemented.
- Least privilege is not consistently enforced.
- User and privileged access reviews are not consistently performed.
- Remote access controls require improvement.

NIST CSF 2.0 Alignment

CSF 2.0 subcategory	Connection to Oscorp finding
PR.AA-01	Shared administrator credentials undermine individual credential accountability.
PR.AA-03	Authentication lacks MFA safeguards for users and privileged access.
PR.AA-05	Least privilege, access entitlements, and periodic reviews are inconsistent.

The following selected CSF 2.0 outcomes are relevant to the scenario-based findings. These mappings are analyst interpretations, not independently verified compliance determinations.

Risk Scenario

Weak IAM controls increase the risk that compromised credentials or inappropriate access could allow an unauthorized individual to access Oscorp systems, sensitive information, or privileged administrative functions.

Business Impact

- Unauthorized access to corporate systems and data.
- Privilege escalation and administrative account compromise.
- Data theft or modification.
- Increased ability for an attacker to move laterally throughout the environment.
- Operational disruption resulting from compromised accounts.

Existing Controls

- Active Directory provides centralized identity management.
- Complex password requirements exist.
- VPN is used for remote access.
- Existing network segmentation provides some limitations on access.

Likelihood: 4/5

Rationale: Credential theft and phishing are common attack methods. Oscorp's lack of MFA, shared administrator credentials, and inconsistent access reviews increase the likelihood that compromised credentials could result in unauthorized access.

Impact: 4/5

Rationale: Compromise of a privileged account could allow an attacker to access sensitive information, modify user permissions, disable security controls, or move laterally across systems. This could result in data compromise and significant operational disruption.

Current Risk

Score: 4*4= 16/25

Risk Treatment

Mitigate

Recommended Actions

8. Implement MFA for users and privileged accounts.
9. Eliminate shared administrator credentials.
10. Implement unique privileged accounts and PAM.
11. Enforce least privilege and role-based access.
12. Establish recurring user and privileged-access reviews.
13. Strengthen remote-access requirements.

Expected Risk Reduction

Strengthening IAM controls would reduce the probability that stolen credentials or excessive permissions result in unauthorized access to critical systems.

Roadmap Priority

P1

R-03 — Vulnerability Management

Supporting Findings

- Vulnerability scanning has historically been performed on an ad-hoc basis.
- No mature, repeatable vulnerability-management lifecycle is established.
- Vulnerability remediation and prioritization require formalization.
- Vulnerability exposure may not be consistently evaluated against asset criticality.
- Vulnerability scanning exists but requires improved governance and repeatability.

NIST CSF 2.0 Alignment

CSF 2.0 subcategory	Connection to Oscorp finding
ID.RA-01	Vulnerability identification and validation are not consistently repeatable.
ID.RA-05	Exploitability and business impact are not consistently used to prioritize risk.
ID.RA-06	Remediation decisions, ownership, and tracking lack a formal lifecycle.

The following selected CSF 2.0 outcomes are relevant to the scenario-based findings. These mappings are analyst interpretations, not independently verified compliance determinations.

Risk Scenario

Without a consistent vulnerability-management program, known security vulnerabilities may remain unidentified or unremediated long enough to be exploited by a threat actor.

Business Impact

- Exploitation of vulnerable systems.
- Unauthorized system access.
- Malware or ransomware infection.
- Data exposure or modification.
- Operational disruption.
- Increased remediation and recovery costs following exploitation.

Existing Controls

- Tenable Vulnerability Management provides vulnerability visibility.
- Microsoft Defender provides endpoint protection.
- Windows endpoints use a standardized operating environment.
- Existing network security controls can reduce some attack paths.

Likelihood: 3/5

Rationale: Oscorp uses Tenable for vulnerability scanning, but assessments have historically been inconsistent and remediation is not formally managed. This increases the possibility that known vulnerabilities remain exposed for extended periods. Existing endpoint and network security controls provide some protection.

Impact: 4/5

Rationale: If a critical vulnerability affecting an important Oscorp system were exploited, it could result in unauthorized access, ransomware, data compromise, or significant operational disruption. An affected system becoming unavailable for several days could interrupt business operations and result in substantial financial and recovery costs.

Current Risk

Score: $3 \times 4 = 12/25$

Risk Treatment

Mitigate

Recommended Actions

14. Establish a formal vulnerability-management lifecycle.
15. Perform recurring authenticated vulnerability scans.
16. Establish risk-based remediation SLAs.
17. Prioritize vulnerabilities using severity, exploitability, exposure, and asset criticality.
18. Assign remediation ownership.
19. Verify remediation through rescanning.
20. Report vulnerability metrics and exceptions to management.

Expected Risk Reduction

A repeatable vulnerability-management program would reduce the time exploitable vulnerabilities remain exposed and improve prioritization of vulnerabilities affecting critical assets.

Roadmap Priority

P2

R-04 — Security Monitoring & Detection

Supporting Findings

- No centralized SIEM capability is established.
- Security logs are not centrally aggregated and correlated.
- No formal security-event analysis and prioritization process exists.
- Detection thresholds and escalation procedures are not formally established.
- Detection capabilities are not routinely tested.
- Detection processes lack formal continuous improvement.

NIST CSF 2.0 Alignment

CSF 2.0 subcategory	Connection to Oscorp finding
PR.PS-04	Security log records are not consistently available for centralized monitoring.
DE.CM-01	Network monitoring is not comprehensively correlated.
DE.CM-09	Computing and endpoint telemetry is not consistently integrated.
DE.AE-03	Security event information is not correlated across sources.
DE.AE-08	Formal incident-declaration criteria are not established.

The following selected CSF 2.0 outcomes are relevant to the scenario-based findings. These mappings are analyst interpretations, not independently verified compliance determinations.

Risk Scenario

Insufficient centralized security monitoring may allow malicious activity to occur without timely detection, increasing the amount of time an attacker can operate within Oscorp's environment.

Business Impact

- Delayed identification of security incidents.
- Increased attacker dwell time.
- Greater opportunity for lateral movement or data theft.
- Increased scope and cost of incident response.
- Reduced ability to reconstruct security events.
- Financial losses associated with prolonged security incidents.
- Disruption of critical business operations.
- Potential compromise of sensitive business information.

Existing Controls

- Microsoft Defender provides endpoint telemetry and alerts.
- Tenable provides vulnerability visibility.
- Physical security monitoring exists.
- Network security infrastructure generates security-relevant information.

Likelihood: 4/5

Rationale: Without centralized security monitoring and established detection procedures, Oscorp is more likely to miss or delay identifying malicious activity. Although Microsoft Defender provides some endpoint detection capabilities, the lack of centralized log correlation, alert prioritization, and defined escalation procedures increases the likelihood that suspicious activity could remain undetected for an extended period.

Impact: 4/5

Rationale: Delayed detection of malicious activity could allow an attacker additional time to move laterally, compromise sensitive information, or disrupt critical systems. This could increase the severity of an incident,

extend response and recovery times, and make forensic investigation more difficult due to incomplete or disconnected security logs.

Current Risk

Score: $4 \times 4 = 16/25$

Risk Treatment

Mitigate

Recommended Actions

21. Implement centralized security logging and SIEM capabilities.
22. Integrate critical endpoint, identity, cloud, and network log sources.
23. Develop prioritized detection rules for relevant threats.
24. Define alert severity and escalation procedures.
25. Establish monitoring responsibilities.
26. Routinely test and tune detection capabilities.

Expected Risk Reduction

Centralized monitoring and defined detection procedures would reduce the time required to identify malicious activity and improve Oscorp's ability to respond before an incident expands.

Roadmap Priority

P1

R-05 — Incident Response

Supporting Findings

- No formal cybersecurity Incident Response Plan exists.
- Incident-response roles and responsibilities are not formally documented.
- Incident severity and escalation criteria are not established.
- Formal containment, mitigation, and eradication procedures are not established.
- No formal digital-forensics capability exists.
- Incident-response exercises are not routinely conducted.
- Lessons learned are not formally incorporated into response improvements.

NIST CSF 2.0 Alignment

CSF 2.0 subcategory	Connection to Oscorp finding
ID.IM-04	Incident response plans and related procedures are not formally maintained.
RS.MA-01	There is no approved incident response plan for coordinated execution.
RS.MA-03	Incident categorization and prioritization criteria are not established.
RS.MA-04	Incident escalation responsibilities and procedures are undefined.
RS.AN-07	Evidence collection and integrity procedures require formalization.

The following selected CSF 2.0 outcomes are relevant to the scenario-based findings. These mappings are analyst interpretations, not independently verified compliance determinations.

Risk Scenario

Without a formal incident-response capability, Oscorp may respond inconsistently or too slowly during a cybersecurity incident, allowing an otherwise containable event to cause greater damage.

Business Impact

- Longer incident duration.
- Greater operational disruption.
- Increased data loss or system compromise.
- Increased recovery and investigation costs.
- Poor coordination and management communication during a crisis.

Existing Controls

- Cybersecurity and IT personnel are available to respond to technical issues.
- Microsoft Defender generates endpoint alerts.
- Business continuity and disaster recovery capabilities exist.
- Recovery and backup procedures are periodically tested.

Likelihood: 4/5

Rationale: Without a formal incident-response plan and clearly assigned responsibilities, Oscorp is likely to experience delays when responding to cybersecurity incidents. Teams may need additional time to determine who is responsible for investigating, containing, and remediating an incident. The lack of established procedures could also result in duplicated efforts, missed steps, or poor coordination, increasing response times.

Impact: 4/5

Rationale: Delayed incident response could allow an attacker additional time to compromise systems, modify privileged accounts, or deploy ransomware before being contained. Although not every security

incident results in significant damage, an ineffective response could increase operational disruption, data loss, and financial recovery costs.

Current Risk

Score: 4*4=16/25

Risk Treatment

Mitigate

Recommended Actions

27. Develop and approve an Incident Response Plan.
28. Define incident-response roles and responsibilities.
29. Establish incident severity and escalation criteria.
30. Develop response playbooks for major incident types.
31. Define containment, eradication, recovery, and evidence-handling procedures.
32. Conduct recurring tabletop exercises.
33. Establish a formal lessons-learned process.

Expected Risk Reduction

Formal incident-response procedures would improve coordination, reduce response time, and limit the potential impact of security incidents.

Roadmap Priority

P1

R-06 — Third-Party Cybersecurity Risk

Supporting Findings

- No formal third-party cybersecurity risk-management process exists.
- Suppliers and external services are not consistently assessed for cybersecurity risk.
- Third-party systems and services are not fully classified based on criticality.
- Cybersecurity requirements are not consistently incorporated into supplier-management processes.
- Oscorp depends on third-party SaaS services, including the critical Horizon Labs platform.

NIST CSF 2.0 Alignment

CSF 2.0 subcategory	Connection to Oscorp finding
GV.SC-01	A formal cybersecurity supply chain risk management process is missing.
GV.SC-04	Suppliers are not consistently prioritized by criticality.
GV.SC-05	Cybersecurity requirements are not consistently embedded in supplier agreements.
GV.SC-06	Security due diligence is not consistently performed before supplier onboarding.
GV.SC-07	Supplier risks are not continuously assessed and monitored.
GV.SC-08	Supplier incident and recovery coordination requires planning.

The following selected CSF 2.0 outcomes are relevant to the scenario-based findings. These mappings are analyst interpretations, not independently verified compliance determinations.

Risk Scenario

Without a formal third-party risk-management process, Oscorp may rely on vendors or SaaS providers with inadequate cybersecurity controls without understanding or appropriately managing the resulting exposure.

Business Impact

- Exposure of Oscorp information through a compromised supplier.
- Operational disruption caused by a critical vendor outage or security incident.
- Unauthorized access through third-party relationships.
- Contractual, regulatory, or reputational consequences.
- Limited ability to respond to supplier-related cybersecurity events.

Existing Controls

- Procurement and financial processes exist for supplier relationships.
- Critical SaaS services are known to the organization.
- Existing technical controls may limit some third-party access.

Likelihood: 3/5

Rationale: Oscorp does not consistently assess or monitor the cybersecurity practices of its third-party suppliers. Although these vendors may have strong security controls, Oscorp lacks sufficient visibility to verify their effectiveness or determine when they were last assessed. This creates the possibility that supplier-related cybersecurity risks could remain unidentified or unmanaged.

Impact: 4/5

Rationale: A cybersecurity incident affecting a critical third-party provider could disrupt essential business processes, compromise sensitive information, or prevent employees from accessing systems required for daily operations. Although recovery procedures or alternative arrangements may reduce the duration of disruption, the impact could still be significant. A severe organization-wide impact is not assumed without further evidence of the provider's critical dependencies.

Current Risk

Score: 3*4=12/25

Risk Treatment

Mitigate

Recommended Actions

34. Establish a formal third-party cybersecurity risk-management process.
35. Maintain an inventory of critical suppliers and SaaS providers.
36. Classify vendors based on business and data criticality.
37. Perform cybersecurity due diligence before onboarding critical suppliers.
38. Establish security requirements in applicable contracts.
39. Periodically reassess high-risk suppliers.
40. Define procedures for supplier security incidents and termination.
41. Develop and maintain recovery and continuity plans for critical suppliers.

Expected Risk Reduction

A formal third-party risk program would provide greater visibility into supplier exposure and allow Oscorp to apply stronger oversight to vendors capable of materially affecting operations or information security.

Roadmap Priority

P2

R-07 — Data Protection & Classification

Supporting Findings

- No formal data-classification framework is established.
- Data Loss Prevention capabilities are not established.
- Sensitive and critical information is not consistently classified or labeled.
- Controls governing the handling of sensitive information require improvement.
- Removable-media controls require improvement.

NIST CSF 2.0 Alignment

CSF 2.0 subcategory	Connection to Oscorp finding
ID.AM-07	Sensitive-data inventories and classification metadata are incomplete.
PR.DS-01	Protection requirements for data at rest are not consistently defined by sensitivity.
PR.DS-02	Protection requirements for data in transit and external sharing need improvement.
PR.DS-10	Controls for sensitive data in use, including removable-media handling, require improvement.

The following selected CSF 2.0 outcomes are relevant to the scenario-based findings. These mappings are analyst interpretations, not independently verified compliance determinations.

Risk Scenario

Without consistent data classification and protection controls, Oscorp may be unable to determine where sensitive information resides or apply security controls appropriate to its business value and sensitivity.

This increases the risk of sensitive information being accessed, transferred, disclosed, or lost without appropriate protection or detection.

Business Impact

- Unauthorized disclosure of sensitive information.
- Loss or theft of business data.
- Inappropriate sharing of confidential information.
- Regulatory or contractual consequences.
- Reputational and financial damage following a data-loss event.

Existing Controls

- Data is primarily hosted within Microsoft Azure and Microsoft 365.
- Existing identity and network controls provide some access restriction.
- Microsoft security technologies provide a foundation for additional information-protection controls.
- Backup and recovery processes exist.

Likelihood: 3/5

Rationale: Without formal data classification and Data Loss Prevention controls, Oscorp may fail to identify sensitive information or prevent inappropriate sharing and transfers. Although existing identity and network controls provide some protection, accidental disclosure or unauthorized data movement remains possible. There is insufficient evidence to conclude that a significant data-loss incident is likely.

Impact: 4/5

Rationale: Unauthorized disclosure of sensitive customer information, confidential business documents, or internal policies could result in significant financial, legal, contractual, and reputational consequences. Depending on the sensitivity and volume of information exposed, Oscorp could face litigation, regulatory scrutiny, or loss of customer trust. While severe consequences are possible, there is insufficient evidence that a data-loss incident would threaten the organization's continued operations.

Current Risk

Score: 3*4=12/25

Risk Treatment

Mitigate

Recommended Actions

- 42. Establish a formal data-classification standard.
- 43. Identify and classify sensitive and business-critical information.
- 44. Define handling requirements for each classification level.
- 45. Implement appropriate information-protection and DLP capabilities.
- 46. Establish controls for removable media and external sharing.
- 47. Periodically review data-protection controls and classifications.

Expected Risk Reduction

Data classification and protection controls would allow Oscorp to apply security requirements based on information sensitivity and reduce the likelihood of unauthorized disclosure or loss of critical information.

Roadmap Priority

P2

Framework Reference and Assessment Limitations

Reference: National Institute of Standards and Technology (NIST), *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29, February 2024, Appendix A. <https://doi.org/10.6028/NIST.CSWP.29>

The NIST CSF 2.0 identifiers above are official subcategory identifiers; the descriptions of their connection to Oscorp are assessment-specific interpretations, not verbatim NIST language. This fictional case study is a targeted risk assessment, not a comprehensive CSF audit or certification. Current risk scores consider the scenario's existing controls. Scores and priorities are project-defined, not prescribed by NIST.